

Security Testing

Autenticación, autorización, sesiones, OWASP, pruebas de seguridad Web y APIs.

Security Testing para QA

Security Testing busca identificar riesgos que puedan comprometer confidencialidad, integridad, disponibilidad y control de acceso. QA puede incorporar verificaciones sin reemplazar especialistas de seguridad.

Autenticación vs autorización

Autenticación responde quién es el usuario; autorización define qué puede hacer. Las pruebas deben cubrir credenciales, sesiones, expiración, roles, permisos e intentos de acceso indebido.

OWASP como referencia

OWASP mantiene materiales ampliamente utilizados para riesgos y pruebas de seguridad web y API. Ayudan a estructurar checklists y aprendizaje técnico.

Inputs y validación

Campos, parámetros, headers y payloads deben tratarse como entradas no confiables. Validación, encoding y controles del servidor son importantes para reducir vulnerabilidades.

Sesiones y tokens

Cookies, tokens, JWT y sesiones necesitan expiración, protección e invalidación adecuadas. Logout, cambio de contraseña y cambio de privilegios requieren escenarios específicos.

API Security

Valide autenticación, autorización por objeto/función, rate limiting, exposición excesiva de datos, mensajes de error y comportamiento con payloads manipulados.

Herramientas

OWASP ZAP puede apoyar análisis dinámico automatizado y manual. Burp Suite es ampliamente utilizado para inspección y pruebas de seguridad. La herramienta no reemplaza la comprensión del riesgo.

DevSecOps y Shift Left

Seguridad puede incorporarse a requisitos, code review, análisis de dependencias, pipelines, pruebas y observabilidad. Detectar antes un riesgo ofrece más opciones de tratamiento.

Consejo de QA

Nunca utilice datos reales ni credenciales de producción en ejemplos públicos de seguridad.

Recursos oficiales

Site oficial: <https://wstg.owasp.org/>